

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

BOLA / IDOR Authorization Test Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	BOLA / IDOR test
Result Type	Vulnerable behaviour observed
Evidence Report File	06-bola-idor-accessing-another-user-data-evidence-report.pdf
Testing Phase	Object-Level Authorization Testing
Tool / Component	Postman / crAPI Endpoint Testing
OWASP / Security Mapping	API1:2023 Broken Object Level Authorization
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

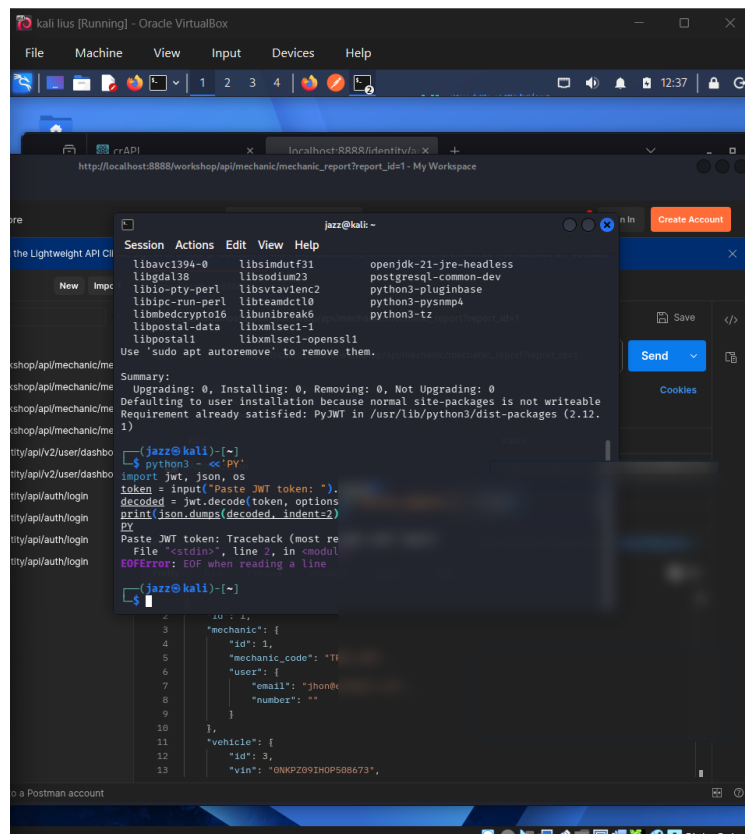


Figure 1 - Embedded screenshot evidence for: BOLA / IDOR test

What this evidence proves

The evidence shows an API request/response workflow consistent with object-level authorization testing. Sensitive user data and identifiers are blurred.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	Object-Level Authorization Testing
Tool / Component	Postman / crAPI Endpoint Testing
Assessment Objective	Validate whether changing an object identifier allows access to another user or another resource that should not belong to the current authenticated user.
Result Type	Vulnerable behaviour observed
OWASP / Security Mapping	API1:2023 Broken Object Level Authorization

Why this evidence matters

BOLA is one of the most important API risks because APIs often expose object IDs directly. The server must verify ownership for every object access, not trust client-provided IDs.

Command / workflow used

```
Authenticate as User A
Request a resource owned by User A
Modify report_id, user_id, vehicle_id, or object identifier
Observe whether data belonging to User B is returned
```

Sanitized output style

```
GET /workshop/api/mechanic/mechanic_report?report_id=<CHANGED_ID>
Authorization: Bearer <REDACTED_TOKEN>
Response: object data returned / reviewed for ownership mismatch
```

3. Professional Interpretation

This evidence row should be interpreted as: **Vulnerable behaviour observed**.

If confirmed in production, BOLA can allow unauthorized reading or modification of other users data, including reports, vehicle records, profile data, or business objects.

Assessor notes

This is one of the strongest API security evidence rows if the response clearly shows cross-user data.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Finding interpretation

Where the evidence shows vulnerable behaviour, the report should explain the security impact, the affected object or workflow, and the remediation without publishing sensitive raw values.

4. Risk, Impact, and Remediation Guidance

Risk perspective

If confirmed in production, BOLA can allow unauthorized reading or modification of other users data, including reports, vehicle records, profile data, or business objects.

Recommended remediation / hardening actions

- Enforce server-side object ownership checks.
- Use centralized authorization middleware.
- Validate every resource ID against the authenticated user.
- Log and alert on repeated unauthorized object access.
- Use indirect references only as an additional defense, not the main control.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Authorization token.
- User emails and IDs.
- Vehicle identifiers.
- Mechanic report data.
- Any personal data returned by the API.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

[BOLA / IDOR test](./reports/evidence/06-bola-idor-accessing-another-user-data-evidence-report.pdf)

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.